State of Wisconsin IT Security Policy Handbook

Owner: Bureau of Security

Effective Date: 11/11/2020

Revision Date: 3/10/2026

Applicable For: Enterprise

TABLE OF CONTENTS

STATUTORY AUTHORITY 4

OVERVIEW 5

SCOPE 5

ROLES AND RESPONSIBILITIES for the IT Security Handbook 5

COMPLIANCE 6

COORDINATION AMONG AGENCIES 6

ENFORCEMENT/SANCTIONS 7

IT SECURITY GOVERNANCE-TERMINOLOGY & DEFINITIONS 7

- Security Policy 7
- Procedure 7
- Standard 7
- Guidelines 7
- Baselines 7

ALIGNMENT WITH IT GOVERNANCE 8

COMMUNICATION 8

SECURITY POLICY AND STANDARDS REVIEW AND MAINTENANCE 9

IT SECURITY POLICIES 10

AC-01 Access Control Policy 10

AT-01 Security Awareness and Training Policy 11

AU-01 Audit and Accountability Policy 12

CA-01 Security Assessment and Authorization Policy 13

CM-01 Configuration Management Policy 14

CP-01 Contingency Planning Policy 15

IA-01 Identification and Authentication 16

IR-01 Incident Response Policy 17

MA-01 System Maintenance Policy 18

MP-01 Media Protection Policy 19

PE-01 Physical and Environmental Protection Policy 20

PL-01 Security Planning Policy 21
PS-01 Personnel Security Policy 22
RA-01 Risk Assessment Policy 23
SA-01 System and Services Acquisition Policy 24
SC-01 System and Communication Protection Policy 25
SI-01 System and Information Integrity Policy 26
PM-01 Program Management Policy 27
PT-01 Personally Identifiable Information Processing and Transparency Policy 28
SR-01 Supply Chain Risk Management Policy 29
191 Data Classification Policy 30
290 Removal of Prohibited Foreign Products Policy 31
Appendix A – ACRONYMS 32
Appendix B – Glossary/Definitions 33
Appendix C – Review, Revision, Approval Log 38

STATUTORY AUTHORITY

Wisconsin State Statutes Chapter 16 SUBCHAPTER VII INFORMATION TECHNOLOGY describes the responsibilities and duties of the Department of Administration (DOA) related to setting policies and procedures for the administration of information technology (IT) services.

Wis. Stat. § 16.971 Responsibilities of department. (2) The department shall:

(a) Ensure that an adequate level of information technology services is made available to all executive branch agencies by providing systems analysis and application programming services to augment agency resources, as requested. The department shall also ensure that executive branch agencies, other than the board of regents of the University of Wisconsin System, make effective and efficient use of the information technology resources of the state. The department shall, in cooperation with the executive branch agencies, establish policies, procedures, and planning processes for the administration of information technology services, which executive branch agencies shall follow. The policies, procedures and processes shall address the needs of agencies, other than the board of regents of the University of Wisconsin System, to carry out their functions. The department shall monitor adherence to these policies, procedures, and processes.

(k) Ensure that all state data processing facilities develop proper privacy and security procedures and safeguards.

Wis. Stat. § 16.973 Duties of the department. The department shall:

(3) Facilitate the implementation of statewide initiatives, including development and maintenance of policies and programs to protect the privacy of individuals who are the subjects of information contained in the databases of agencies, and of technical standards and sharing of applications among executive branch agencies and any participating local governmental units or entities in the private sector.

(4) Ensure responsiveness to the needs of executive branch agencies for delivery of high-quality information technology processing services on an efficient and economical basis, while not unduly affecting the privacy of individuals who are the subjects of the information being processed by the department.

(5) Utilize all feasible technical means to ensure the security of all information submitted to the department for processing by executive branch agencies, local governmental units, and entities in the private sector.

OVERVIEW

Pursuant to DOA's statutory authority in Wisconsin Statutes Chapter 16, the Division of Enterprise Technology in collaboration with executive branch agencies, has developed the State of Wisconsin IT Security Policy Handbook to establish policies for the administration of information technology services. This handbook provides the baseline IT security policies and controls for executive branch agencies and an explanation of terms for guiding principles, policies, standards, procedures, and key components of the IT security approach and governance process. Included in this handbook are all current security policies with links to associated standards. As provider of the State of Wisconsin consolidated data center services, which involve a multitude of federal and state regulatory requirements, DOA has adopted the NIST Special Publication 800-53, Revision 5, as the foundational framework for the executive branch IT security policies and standards. NIST Special Publication 800-53, Revision 5 provides the recommended baseline security controls for governmental organizations. As a currently established baseline for implementation, all designated low and moderate level controls as well as selected high-level controls from NIST Special Publication 800-53, Revision 5 are utilized in support of security posture initiatives.

SCOPE

All State of Wisconsin executive branch agencies, excluding the Board of Regents of the University of Wisconsin System, shall adhere to these policies. See Wis. Stat. § 16.971(2)(a). Non-executive branch agencies are strongly encouraged to adopt and adhere to these policies. As needed to address business or specific regulatory requirements, agencies may choose to implement more rigorous policies and standards in relation to their agency-specific applications and processes.

ROLES AND RESPONSIBILITIES for the IT Security Handbook

- Chief Information Officer (CIO)
    - Ensures that DOA drafts, finalizes, and promulgates executive branch IT security policies.

- Chief Information Security Officer (CISO)
    - Develops and administers the DOA/Division of Enterprise Technology (DET) IT Security Program.
    - Formulates any DOA-specific IT security standards.
    - Provides guidance to management in interpreting federal, state, and local security laws and requirements.

- Administrative Officers (AO)
    - Ensures the implementation of IT security policies and standards within their respective executive branch agencies.

- Deputy Chief Information Security Officer (Deputy CISO)
    - Researches and develops necessary IT security policies, standards, and procedures.
    - Maintains the IT security policies, standards, and procedures review

schedule for DOA/DET.
- Publishes updates to the DOA/DET Portal as necessary.
- Facilitates the processing of any requests for exceptions to executive branch IT security policies and standards.
- Provides IT security compliance consulting support as it relates to regulatory requirements and security industry best practices.

COMPLIANCE

The executive branch IT security policies contained in this handbook take effect upon publication, unless explicitly noted within the policy or standard. The DOA/DET Bureau of Security will facilitate an annual review of the handbook to ensure relevancy and to coordinate with executive branch agencies on any needed updates.

DOA/DET shall monitor compliance with the policies, standards, and procedures in this handbook. See Wis. Stat. § 16.971(2)(a). If compliance with particular policies or related standards is not feasible or technically possible, or if deviation is justifiable to support a business function, agency representatives shall request an exception through the DOA/DET Bureau of Security Exception Procedure DETCC Enterprise Policies Standards and Procedures (wi.gov).

COORDINATION AMONG AGENCIES

The State of Wisconsin executive branch agencies are subject to various regulatory requirements designed to ensure the effective implementation of appropriate IT security measures. Listed below are some of the primary regulatory requirements that the executive branch agencies are subject to:

- Centers for Medicare and Medicaid Services (CMS) - Catalog of Minimum Acceptable Risk Security and Privacy Controls for Exchanges, Version 2.2 (MARS-E)
- Criminal Justice Information Services CJIS Security Policy (CJISSECPOL v6)
- Driver's Privacy Protection Act (DPPA)
- Family Educational Rights and Privacy Act (FERPA) Compliance
- Federal Information Security Management Act (FISMA)
- Health Insurance Portability and Accountability Act (HIPAA)
- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- Payment Card Industry – Data Security Standard (PCI-DSS)
- Social Security Administration (SSA) Technical System Security Requirements
- Wisconsin State Statutes Chapter 16.971
- Wisconsin State Statutes Chapter 16.705(1r)
- General Records Schedule – Information Technology and Related Records

Executive branch agencies share responsibility for safeguarding assets and information which includes but is

not limited to: Federal Tax Information (FTI), Protected Health Information (PHI), Personally Identifiable Information (PII) and other private information concerning individuals and entities. Security mechanisms are employed for coordinating the access and protection of audit information among external organizations when audit information is transmitted across executive branch agency boundaries. See Wis. Stat. § 16.973(3) & (5).

ENFORCEMENT/SANCTIONS

Enforcement of the security policies applying to executive branch state agencies shall be conducted at the agency level. All determinations regarding appropriate sanctions for violations of executive branch IT security policies shall be facilitated by agency Human Resources management.

IT SECURITY GOVERNANCE – TERMINOLOGY AND DEFINITIONS

Security policy - A security policy is a document that defines the scope of security needed by the organization and discusses the assets that require protection and the extent to which security solutions should go to provide the necessary protection. The security policy is an overview or generalization of an organization's security needs, it defines the main security objectives and outlines the security framework, clearly defines why security is important and what assets are valuable and should broadly outline the security goals and practices that should be employed to protect the organization's vital interests.

Procedure - A procedure is a detailed, how-to document that describes the exact actions necessary to implement a specific security mechanism, control, or solution, and are software/hardware/system specific. A procedure can discuss the entire system deployment operation or focus on a single product or aspect. Procedures shall be updated as software/hardware and systems evolve, and to ensure the integrity of business processes through standardization and consistency of results. Procedures are the bare minimum steps needed to meet standards.

Standard - Standards define compulsory requirements for the homogenous use of hardware, software, technology, and security controls. They provide a course of action by which technology and procedures are uniformly implemented throughout an organization and are tactical documents that define steps or methods to accomplish the goals and overall direction defined by the security policies.

Guidelines - A guideline offers recommendations on how standards and baselines are implemented and serves as an operational guide for both security professionals and users and are flexible so they can be customized for each unique system or condition and can be used in the creation of new procedures. Additionally, they state which security mechanisms should be deployed instead of prescribing a specific product or controls and detailing configuration settings. They outline methodologies, include suggested actions, and are not compulsory.

Baselines - A baseline defines a minimum level of security that every system throughout the organization shall meet. A baseline is a more operationally focused form of a standard and establishes a common foundational secure state on which all additional and more stringent security measures can be built. Baselines are usually system specific and often refer to an industry or government standard.

Policies, standards, and procedures work together to prescribe the State's IT operations and frame the key components of the State's IT security approach and governance process.

As noted previously, this State of Wisconsin IT Security Policy Handbook provides the baseline of security policies DET requires agencies to comply with. These **policies** define the scope of the security measures needed to protect the State and the extent to which security solutions should go to provide necessary protection to state information. These policies contain high-level statements and plans based on DOA-DET's goals, objectives, and regulatory authority to overview the State's security needs and provide the required security framework for agencies.

Each security policy references the standards associated with that policy. The **standards** make up the actions or rules an agency shall follow to conform to the policy. They detail DET's requirements for hardware, software, and other technology used by the State and the requirements for uniform implementation throughout the enterprise. In contrast to the policies, the standards are detailed, tactical documents that define the methods to accomplish the State's security goals and objectives.

DET does not generally prescribe the procedures for agencies to follow. Agencies are responsible for creating their own **procedures** that are a detailed guide that describes the exact actions necessary to implement the required standard and policy. A procedure can discuss the entire system deployment operation or focus on a single product or aspect of implementation.

ALIGNMENT WITH IT GOVERNANCE

The following will ensure consistent oversight of all IT security guiding principles, policies, and standards.

- DOA shall present the executive branch IT security policies to Agency Security Officers, IT Directors and Administrative Officers on an annual basis for review.
- DOA shall publish the executive branch IT security guiding principles, policies, and standards.
- Agencies may implement more rigorous policies and standards in relation to agency-specific applications and processes, as needed to address business requirements.
- Each agency shall create, maintain, and disseminate to its employees the procedures that accomplish the end-goal executive branch IT policies and standards provided in this handbook. Where the agency employs more rigorous policies and standards in relation to *agency-specific* applications and processes, the agency may maintain and disseminate procedures that accomplish the agency's more rigorous policies and standards.

COMMUNICATION

- DOA shall publish the current and approved security guiding principles, policies, and

standards that apply to executive branch agencies to the DOA/DET Customer Portal.

- Each agency shall communicate the policies, standards, and procedures to which it is subject to all their appropriate personnel upon approval.
- DOA shall incorporate the executive branch IT security policies and standards into the State of Wisconsin IT Security Awareness Training Program.

SECURITY POLICY AND STANDARDS REVIEW AND MAINTENANCE

DOA/DET Bureau of Security shall implement the following processes to ensure compliance with regulatory requirements.

- The State of Wisconsin IT Security Policy Handbook and executive branch standards shall be reviewed annually by the DOA/DET Bureau of Security. When specific language changes are necessary in either the IT Policy Handbook or standards documents to add clarity or resolve any discrepancies between policies and standards, this can be accomplished without a formal review process. However, agencies shall be notified via email, through WI-ISAC, Enterprise IT and the Administrative Officer Counsel. Additionally, agencies are encouraged to contact the DOA/DET Bureau of Security and provide input where language in the IT Policy Handbook or standards can be improved in this manner.
- DOA/DET Bureau of Security may choose to update the IT Policy Handbook or standards without a formal review process or initial collaboration with agencies for the purposes of correcting technical or clerical errors, clarifying an agency's requirements, or resolving discrepancies between the policies and standards. However, agencies shall be notified of any changes made through WI-ISAC, Enterprise IT and the Administrative Officer Counsel.
- Agencies are encouraged to submit feedback and provide input to DOA/DET Bureau of Security on possible improvements to the IT Policy Handbook and standards.
- DOA/DET Bureau of Security personnel shall:
    - Document policy review and approval procedures.
    - Maintain the policy review schedule.
    - Publish IT security guiding principles, policies, and standards that apply to executive branch agencies to the DOA/DET Customer Portal.
    - Maintain a single repository for documentation that applies to all executive branch agencies.
    - Coordinate the review and tracking of exception requests to executive branch agency IT security policies and standards.

IT SECURITY POLICIES

AC-01 Access Control Policy

Purpose

The purpose of this policy is to establish the requirements and expectations supporting 'Access Control' capability to maintain Confidentiality, Integrity, and Availability (CIA) of the State of Wisconsin information systems environment and its data. The Access Control Policy is for managing security and privacy risks associated with user account management, access enforcement and monitoring, insufficient separation of duties, lack of adherence to the principle of least privilege and remote access security. The related access control standards will facilitate the implementation of security best practices for logical security, account management, and remote access.

Policy

System Access may only be granted upon receipt of an approved agency "Access Request Form" from an authorized submitter. E-forms are included as an approved request form. The granting of access privileges must follow the principle of least privilege, be appropriate to job role, and commensurate with appropriate account management assignments (user, privilege, and system accounts). Executive branch agencies will develop formal and documented procedures to ensure consistent practices regarding account management.

Standards Associated with the Access Control Policy

- Access Control Standard (100)
- Access Control for Remote Access Standard (101)
- Access Control for Wireless Access Standard (102)
- Access Control for Mobile Device Security (103)
- Identification and Authentication Standard (160)
- Personnel Security Standard (220)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- Internal Revenue Service Special Publication 6103
- NIST Special Publication 800-53, Revision 5

Purpose

The Security Awareness and Training Policy is for managing risks from a lack of IT security awareness, communication, and training through the establishment of an effective security awareness and education program. The security awareness and education program will train agency personnel, contractors, and interns on security best practices and concepts.

Policy

Executive branch agencies shall develop and/or procure and make available online security awareness training with a focus on security best practices, role-based security and responsibilities for all agency personnel, contractors, and interns to ensure an understanding of agency security policies and current IT security best practices. It is a requirement that any individual issued a computer account by an executive branch state agency – including employees, contractors, interns, volunteers, and business partners – receive security awareness training and disclosure training. This training shall take place upon issuance of the computer account by the agency and include annual refresher security awareness training. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding security awareness training.

Standards Associated with the Security Awareness and Training Policy

- Security Awareness and Training Standard (110)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- Internal Revenue Service Special Publication 6103
- NIST Special Publication 800-53, Revision 5

Purpose

The Audit and Accountability Policy is for managing risks from inadequate event logging and transaction monitoring. The related audit and accountability standard ensures the implementation of security best practices regarding event logging and transaction monitoring and the retention of audit evidence.

Policy

The audit and log functions of executive branch agencies shall enable the detection and capture of event data of unauthorized access to sensitive and classified information, and information requiring regulatory protection. Audited events shall be reviewed regularly and where possible when unauthorized access events have been identified.

Auditing shall be enabled to the greatest extent necessary to capture access, modification, deletion, and movement of sensitive and classified information by unique username/ID. Event storage retention shall remain in compliance with regulatory requirements and be supported with an appropriate amount of storage for the required retention period.

Time-stamp capabilities shall be synchronized for monitoring auditable devices and events. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding audit and log functionality.

Standards Associated with the Audit and Accountability Policy

- Audit and Accountability Standard (120)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5

Purpose

The Security Assessment and Authorization Policy is for managing risks from inadequate security assessments, authorization, and continuous monitoring of executive branch agency information assets through the establishment of an effective security assessment program. This policy and the associated standard help to implement security best practices regarding security assessments, authorization, and continuous monitoring.

Policy

Develop and conduct periodic security assessment(s), which may include vulnerability and penetration tests, which evaluate and document security measures in place on all critical agency IT systems and system environments. Executive branch agencies shall define the appropriate timeframes for conducting these assessments based on security best practices and regulatory compliance (if applicable). Security assessment reports shall be formally documented and reported to agency management, with a description of the assessment controls being evaluated, associated findings/observations, definition of the assessment environmental landscape, remediation activities, owner, and identification of the assessment team. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding security assessments.

Standards Associated with the Security Assessment and Authorization Policy

- Security Assessment and Authorization Standard (130)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5
- Payment Card Industry – Data Security Standard (PCI-DSS)

Purpose

The Configuration Management Policy is for managing risks from system changes impacting baseline configuration settings, system configuration, and security based on the principle of "least functionality." The configuration management standard shall help document, authorize, manage, and control system changes impacting information system components within the control of the executive branch agency.

Policy

To ensure a secured and consistent implementation of protection mechanisms, baseline configurations and supporting procedures for all agency applications shall be developed, documented, and maintained. These baselines should follow best practices, e.g., those outlined by the Center for Internet Security (CIS) Benchmarks or the United States Government Configuration Baseline (USGCB). Regulatory requirements shall be reviewed at least annually, and updates made to agency systems environments as needed. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding configuration management.

Standards Associated with the Configuration Management Policy

- Configuration Management Standard (140)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5

Purpose

To ensure continuation of operations, the Contingency Planning Policy is for managing risks from information asset disruptions, failures, and disasters through the establishment of effective contingency planning procedures. The contingency planning procedures ensure the implementation of security best practices regarding business continuity and disaster recovery plans.

Policy

All essential executive branch agency systems shall be identified and documented within a formal contingency plan, along with procedures that define recovery objectives, restoration priorities, success metrics that include recovery time and recovery point objectives, roles and responsibilities, and contact lists. The contingency plan shall be reviewed on an annual basis. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding business continuity and disaster recovery plans.

Standards Associated with the Contingency Planning Policy

- Contingency Planning Standard (150)

Compliance References

- Health Insurance Portability and Accountability Act (HIPAA)
- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5

IA-01 Identification and Authentication Policy

Purpose

The Identification and Authentication Policy is for managing risks from user access (agency, non-agency) and authentication into executive branch agency information assets through the establishment of an effective identification and authentication program.

Policy

Prior to establishing a connection to any state agency-managed network (internal or external), or enterprise systems, individuals must be uniquely identified and authenticated following formally documented procedures.

For password-based authentication IA-5(1), where a memorized secret is required, Executive Branch agencies shall implement the baseline requirements as defined appropriately by the State of Wisconsin. Executive Branch agencies throughout the State of Wisconsin may also be subject to additional Federal, State, Local and/or Inter-agency regulatory requirements. Therefore, it is each agency's responsibility to research and implement additional requirements above and beyond the State of Wisconsin baseline.

Standards Associated with the Identification and Authentication Policy

- Access Control Standard (100)
- Identification and Authentication Standard (160)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5
- NIST Special Publication 800-63 – Digital Identity Guidelines
- DOJ FBI Criminal Justice Information Services Division – CJIS Security Policy (CJISSECPOL v6)
- NIST Special Publication 800-66r2 - Implementing the HIPAA Security Rule
- NIST Special Publication 800-122 - Protecting PII

Purpose

The Incident Response Policy is for establishing guidelines for the identification, response, reporting, assessment, analysis, and follow-up to all suspected information security incidents. The agency's related information security response procedures help to ensure the security, confidentiality, integrity and availability of electronic information and the automated systems that contain it and the networks over which it travels.

Policy

This policy requires the definition of a consistent operational approach for responding to identified or reported IT security incidents. An executive branch agency shall develop formal incident response procedures that include the areas of IT security incident event identification, notification, containment, eradication, and recovery.

Executive branch agencies shall:

- Train personnel, including contractors, in their incident response roles.
- Test the incident response capability at least annually.
- Require personnel to report suspected security, privacy, and supply chain incidents by following their agency incident response procedure.
- Develop an incident response plan that provides the agency with a roadmap for implementing its incident response capability.

Standards Associated with the Incident Response Policy

- Incident Response Standard (170)

Compliance References

- Criminal Justice Information Services CJIS Security Policy (CJISSECPOL v6)
- Health Insurance Portability and Accountability Act (HIPAA)
- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5
- Payment Card Industry – Data Security Standard (PCI-DSS)

Purpose

The System Maintenance Policy is for managing risks associated with information asset maintenance and repairs. The related System Maintenance standard and development of procedures shall ensure the implementation of security best practices regarding system maintenance and repairs.

Policy

Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding the planning, scheduling, performing, documenting, reviewing, and recording of maintenance and repairs for all agency-controlled IT system components in accordance with manufacturer or vendor specifications, or in accordance with any relevant DOA/DET requirements for information system maintenance.

Personnel performing maintenance on the information system components shall have appropriate identification and/or been previously authorized by the executive branch agency.

Standards Associated with the System Maintenance Policy

- System Maintenance Standard (180)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5

Purpose

The Media Protection Policy is for managing risks from media access, media storage, media transport, and media protection through the establishment of effective Media Protection standards and procedures. The related media protection standard and procedures shall ensure the implementation of security best practices and control activities regarding media usage, storage, and disposal (media being digital or non-digital media).

Policy

Access controls to all sensitive and confidential information shall restrict access to both digital and non-digital media to only authorized personnel using physical and logical access control mechanisms. Protection mechanisms shall be implemented to protect sensitive or regulated information whether at rest or in transit. Media protection is required during the life cycle of the storage medium until such time the media has been physically destroyed or sanitized using only approved destruction equipment, techniques, and procedures. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding media protection.

Standards Associated with the Media Protection Policy

- Media Protection (190)

Compliance References

- Criminal Justice Information Services CJIS Security Policy (CJISSECPOL v6)
- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5
- Payment Card Industry – Data Security Standard (PCI-DSS)
- General Records Schedule – Information Technology and Related Records

Purpose

The Physical and Environmental Protection Policy is for mitigating the risks from physical security and environmental threats through the establishment of an effective physical security and environmental control standard and procedures. The physical security and environmental controls program help protect IT assets from physical and environmental threats whether internal or external.

Policy

Physical access to DOA/DET infrastructure facilities where protected/restricted information and system assets or infrastructure reside shall be restricted to authorized personnel based upon the principle of least privilege. This policy applies to both DOA and executive branch agency personnel. For visitors, documentation shall be retained to capture the individual's identification by showing formal identification – e.g., driver's licenses and state or government IDs containing a photo. All personnel granted access to restricted buildings shall display appropriate identification badges above the waist.

As provider of the State of Wisconsin consolidated data center, DET shall protect environmental control equipment (HVAC), monitoring systems and required power cabling, control boxes, and piping from inappropriate access, tampering, damage, and destruction. Further protection of the infrastructure components shall include emergency shutoff, power, lighting, fire protection (detection and suppression), temperature and humidity controls, and water damage.

Executive branch state agencies shall also utilize appropriate physical and environmental protection mechanisms at all alternate work sites where protected/restricted information resides. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding physical and environmental protection.

Standards Associated with the Physical and Environmental Protection Policy

- Physical and Environment Protection Standard (200)

Compliance References

- Health Insurance Portability and Accountability Act (HIPAA)
- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5
- Payment Card Industry – Data Security Standard (PCI-DSS)

Purpose

The Security Planning Policy is for managing risks from inadequate security planning through the establishment of an effective security planning program. The related security planning standard and procedures ensure the implementation of security best practices for security planning, preparation, and strategy development.

Policy

Executive branch agencies shall develop and maintain IT security and privacy plans for moderate and high-risk systems or when required by Federal regulatory requirements (if applicable). The plans should include security and privacy measures taken to protect all information assets located at alternate agency work sites and the agency's responsibilities in assuring the security of information in transit to and from the State of Wisconsin consolidated data center. Agencies planning to deploy new applications or major upgrades to existing applications shall conduct a security risk analysis. If the agency identifies security issues that may require modification to the agency security or privacy plan, the agency has the responsibility to consult with the DET Bureau of Security to review the proposed modifications. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding security planning, preparation, and strategy development.

Standards Associated with the Security Planning Policy

- Security Planning Standard (210)

Compliance References

- Health Insurance Portability and Accountability Act (HIPAA)
- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5
- Payment Card Industry – Data Security Standard (PCI-DSS)

Purpose

The Personnel Security Policy is for managing risks from personnel screening, termination, management, and third-party (contractors, vendors, interns) access, through the establishment of effective security planning procedures. The personnel security procedures ensure the implementation of security best practices regarding personnel screening, termination, transfer, and management.

Policy

Executive branch agencies are required to document and utilize appropriate personnel screening and/or background checks prior to initiating employment of new hires. Similarly, executive branch agencies are required to document and utilize appropriate security measures and checklists at the time an employee separates from the agency. The personnel security requirement for each type of role in the agency shall be formally documented and monitored for individual compliance. Third-party vendors or contractors working for the agency are also subject to established agency security policies. Access agreements between the executive branch agency and vendor/contractors shall be reviewed and updated on a periodic basis defined and documented by the agency. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding personnel screening, termination, transfer, and management.

Standards Associated with the Personnel Security Policy

- Personnel Security Standard (220)

Compliance References

- Criminal Justice Information Services CJIS Security Policy (CJISSECPOL v6)
- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5
- 2017 Wisconsin Act 154

Purpose

The Risk Assessment Policy is established so that the impact of an information system compromise can be reduced in an efficient manner. The related risk assessment standard and procedures shall ensure the implementation of security best practices regarding the identification of known vulnerabilities to State of Wisconsin information assets.

Policy

Timely risk assessments of the executive branch agency's business functions, information assets and systems are required to protect against potential threats and vulnerabilities in the areas of confidentiality, integrity, and availability of protected and restricted information and of information and systems necessary in carrying out State responsibilities.

Assessments consist of steps to:

- Determine business requirements and potential business impacts from compromise.
- Identify the impact that could occur from an information system compromise.
- Determine areas of vulnerabilities.
- Identify threats and the likelihood of compromise.
- Initiate appropriate remediation activities to remediate or mitigate vulnerabilities and threats.

Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding risk assessments.

Standards Associated with the Risk Assessment Policy

- Risk Assessment Standard (230)
- Data Classification Standard (191)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5
- NIST Special Publication 800-60

Purpose

The System and Services Acquisition Policy is for managing risks from third party products and service providers, through the establishment of an effective third-party risk management plan. The related system and services acquisition standard and procedures help to ensure the implementation of security best practices regarding the acquisition of systems and services from third-party providers.

Policy

The acquisition of systems (assets) and services from third-party providers are subject to a security assessment review by the executive branch agency to address compliance to established security policies, procedures, and standards prior to the actual purchase or contracting of services. Regulatory compliance shall be maintained post implementation and throughout the life cycle of the product or service contracts being acquired. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding system and services acquisitions.

Standards Associated with the System and Services Acquisition Policy

- System and Services Acquisition Standard (240)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5

Purpose

The System and Communications Protection Policy is for managing risks from vulnerable system configurations, denial of service, data communication, and transfer. The associated system and communications protection standard and procedures help implement security best practices regarding system configuration, data communication, and transfer as they relate to the confidentiality, integrity, and availability of information.

Policy

Sensitive and confidential agency information, whether at rest or in-transit, must be protected from accidental or intentional threats that could corrupt, modify, delete, or disclose that information. Controls shall consider threats from denial of service, attacks against network boundaries, transmission mechanisms, network disconnects, collaborative computing devices, other critical system components, multi-function devices, and printers. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding system and communication protection.

Standards Associated with the System and Communication Protection Policy

- System and Communications Protection Standard (250)

Compliance References

- Health Insurance Portability and Accountability Act (HIPAA)
- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5

SI-01 System and Information Integrity Policy

Purpose

The System and Information Integrity Policy is for managing risks from system flaws/vulnerabilities, malicious code, unauthorized code changes, and inadequate error handling. The related system and information integrity standard and procedures help the executive branch agency implement security best practices regarding system configuration, security, and system and information error handling processes and procedures.

Policy

Executive branch agency business systems shall:

- Identify, report, and correct information system flaws.
- Test software updates related to flaw remediation for effectiveness and potential side effects on organizational information assets before installation.
- Incorporate flaw remediation and error handling into the organizational configuration management process.
- Employ, configure and update malicious code protection mechanisms at information asset entry and exit points and at workstations or mobile computing devices on the network to detect and eradicate malicious code.
- Develop formal and documented procedures to ensure consistent practices regarding system and information integrity.

Sensitive and regulated information shall maintain its integrity and be protected against compromise by potential threats and vulnerabilities. All critical security event mechanisms shall have event detection monitoring, capturing, and reporting of violation events. Security violation event records are required to be logged and retained based on current regulatory requirements applicable to the agency applications (e.g., currently seven years for IRS, 10 years for CMS).

Standards Associated with the System and Information Integrity Policy

- System and Information Integrity Standard (260)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5

Purpose

The Information Security Program was developed in response to the following requirements:

- Wisconsin Statutes Chapter 16 assigns responsibility of proper privacy and security procedures/safeguards; information security planning; threat-mitigation; and resource development to the Department of Administration.
- NIST Special Publication 800-53 Revision 5, which defines baseline security controls for governmental organizations, requires identification and documentation of the senior-level official(s) responsible for information security programs.

Policy

Management of the State's Information Security Program is provided by:

- The executive branch IT Security Policy Handbook shall provide a baseline of security policies and controls throughout executive branch agencies. DOA/DET shall publish and maintain these policies and related standards.
- Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding program management that includes a plan of action and milestones and a system inventory.
- As needed to address business requirements, agencies can employ more rigorous policies and standards in relation to agency-specific applications and processes.
- DOA/DET shall ensure that the executive branch state agency IT security policies and standards are reviewed at least annually.

Standards Associated with the Program Management Policy

- Program Management Standard (500)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5

PT-01 Personally Identifiable Information Processing and Transparency Policy

Purpose

The Personally Identifiable Information Processing and Transparency Policy is for managing risks from inadequate collection, processing, and maintenance of personally identifiable information. The related personally identifiable information processing standard ensures the implementation of security best practices regarding processing personally identifiable information.

Policy

Processing of personally identifiable information (PII) shall be restricted to only that which is authorized. Executive branch agencies shall take steps to ensure that personally identifiable information is only processed for authorized purposes, including training agency personnel on the authorized processing of personally identifiable information and monitoring and auditing agency use of personally identifiable information. Individuals shall be provided with notification about and give consent for the processing of PII. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding processing PII.

Standards Associated with the PII Processing and Transparency Policy

- Personally Identifiable Information Processing and Transparency Standard (270)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5

SR-01 Supply Chain Risk Management Policy

Purpose

The Supply Chain Risk Management Policy is for managing risks from inadequate protection against supply chain threats. The related supply chain risk management standard and procedures help the executive branch agency implement security best practices regarding security or privacy risks to the supply chain.

Policy

Executive branch agencies shall take steps to ensure supply change security and manage potential risks to the supply chain. Supply chain risk management activities include identifying and assessing risks, determining appropriate risk response actions, developing supply chain risk management plans to document response actions, and monitoring performance against plans. Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding supply chain management.

Standards Associated with the Supply Chain Risk Management Policy

- Supply Chain Risk Management Standard (280)

Compliance References

- Internal Revenue Service (IRS) Publication 1075 (Rev. 11/21)
- NIST Special Publication 800-53, Revision 5

191 Data Classification Policy

Purpose

The Data Classification Policy supports a comprehensive Governance, Risk, and Compliance (GRC) program and is consistent with information security best practices associated with organizational information security management. The purpose of the Data Classification policy is to establish the administrative, technical, and physical directives, requirements, guidelines, recommendations, processes, and any other related Local, State, and Federal privacy and security compliance requirements as set forth by DOA supporting the classification of data residing on State of Wisconsin information systems.

Policy

The intent of this policy is to ensure that State of Wisconsin information assets shall be identified, categorized, and labeled. Information assets that have data at multiple classifications must be identified, categorized, and labeled as the highest identified classification level. Agencies shall reflect their data classification security controls through the bi-annual reporting process to Wisconsin Department of Administration/Division of Enterprise Technology (WI DOA-DET) to ensure consistent practices regarding data classification management.

Standards Associated with the Data Classification Policy

- Data Classification Standard (191)

Compliance References

- NIST Special Publication 800-53, Revision 5
- NIST Special Publication 800-60v2r1: Appendices to Guide for Mapping Types of Information and information systems to Security Categories
- Federal Information Processing Standards (FIPS-199)
- PII (Personally Identifiable Information): Wis. Stat. § 19.62(5) defines personally identifiable information (PII)
- Records retention obligations of state agencies Wis. Stat. § 16.61 defined in Wis. Stat. § 16.61(2)(b).
    - State agency-specific Records Disposition Authorization (RDA) Public Records Board > State Agency-Specific RDAs
    - General Records Schedules are a mechanism for consistent retention and disposition of similar types of records across all government units. Statewide General Records Schedules.

290 Removal of Prohibited Foreign Products Policy

Purpose

The Removal of Prohibited Foreign Products Policy is for managing products and applications from certain vendors that present an unacceptable level of cybersecurity risk to the State. The related removal of prohibited foreign products standard ensures the identification of foreign applications and vendors that may present a risk to state information or state information systems.

Policy

Executive branch agencies shall take steps to ensure business functions, information assets and systems are protected against potential threats and vulnerabilities in the areas of confidentiality, integrity, and availability of information and systems necessary in carrying out State responsibilities. These steps include identifying and removing prohibited foreign products from manufacturers or vendors that may participate in activities such as but not limited to:

- Collecting sensitive citizen, financial, proprietary, intellectual property, or other business data.
- Enabling email compromise and acting as a vector for ransomware deployment.
- Conducting cyber-espionage against government entities.
- Conducting surveillance and tracking of individual users.
- Using algorithmic modifications to conduct disinformation or misinformation campaigns.

Executive branch agencies shall develop formal and documented procedures to ensure consistent practices regarding removal of prohibited foreign products.

Compliance References

- Wis. Stat. § 16.754
- Executive Order 184: https://evers.wi.gov/pages/newsroom/executive-orders.aspx

Appendix A – ACRONYMS

Common IT security abbreviations adopted from NIST Special Publication 800-37, Revision 2, and the State of Wisconsin

- AO Administrative Officer
- APT Advanced Persistent Threat
- CIO Chief Information Officer
- CISO Chief Information Security Officer
- CJIS Criminal Justice Information Services
- CPO Chief Privacy Officer
- DOA/DET Department of Administration – Division of Enterprise Technology
- DNS Domain Name System
- DOA Department of Administration
- DoD Department of Defense
- FAR Federal Acquisition Regulation
- FEA Federal Enterprise Architecture
- FERPA Family Educational Rights and Privacy Act
- FICAM Federal Identity, Credential, and Access Management
- FIPS Federal Information Processing Standards
- FISMA Federal Information Security Management Act
- HIPAA Health Insurance Portability and Accountability Act
- HSPD Homeland Security Presidential Directive
- IPsec Internet Protocol Security
- IRS Internal Revenue Service
- LACS Logical Access Control System
- NIST National Institute of Standards and Technology
- NSA National Security Agency
- OMB Office of Management and Budget
- OPSEC Operations Security
- PCI-DSS Payment Card Industry Data Security Standard
- PII Personally Identifiable Information
- PIV Personal Identity Verification
- PKI Public Key Infrastructure
- RMF Risk Management Framework
- SCADA Supervisory Control and Data Acquisition
- SP Special Publication
- TCP/IP Transmission Control Protocol/Internet Protocol
- USB Universal Serial Bus
- USGCB United States Government Configuration Baseline
- VoIP Voice over Internet Protocol
- VPN Virtual Private Network

Appendix B – Glossary/Definitions

Common IT security terms adopted from NIST Special Publication 800-37, Revision 2, and the State of Wisconsin

Term	Definition
Access Control	Security control designed to permit authorized access to an IT system or application.
Accessible	Information arranged, identified, indexed, or maintained in a manner that permits the custodian of the public record to locate and retrieve the information in a readable format within a reasonable time.
Authentication	Verification of the identity of a user, user device, or other entity, or the integrity of data stored, transmitted, or otherwise exposed to unauthorized modification in an IT.
Authorization	Access privileges granted to a user, program, or process or the act of granting those privileges.
Availability	The extent to which information is operational, accessible, functional, and usable upon demand by an authorized entity (e.g., a system or user).
Confidentiality	The property that information is not made available or disclosed to unauthorized individuals, entities, or processes.
Configuration Management	The process of keeping track of changes to the system, if needed, approving them.

Term	Definition
Contingency Plan	A plan for emergency response, backup operations, and post-disaster recovery maintained by an activity as a part of its security program that will ensure the availability of critical resources and the successful continuity of operations in an emergency.
Control	An action taken to enhance the likelihood that established goals or objectives will be achieved (in the context of this handbook, generally an action taken to reduce risk).
Data	A subset of information in an electronic format that allows it to be retrieved or transmitted.
Executive Branch Agencies	Administrative departments, executive agencies, boards, and councils of the State of Wisconsin executive branch of government as described in the State of Wisconsin Blue Book. For these enterprise security policies, the UW System is not included, though the UW System is in the executive branch.
Identification	The process that enables a user described to an IT system or service.
Digital Media	A form of electronic media where data are stored in digital (as opposed to analog) form.
Information Security	The protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction to provide confidentiality, integrity, and availability.

Term	Definition
Incident	An occurrence that actually or potentially jeopardizes the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits or that constitutes a violation or imminent threat of violation of security policies, security procedures, or acceptable use policies.
Incident Response	The manual and automated procedures used to respond to reported network intrusions (real or suspected); network failures and errors; and other undesirable events.
Information	Any communication or representation of knowledge such as facts, data, or opinions in any medium or form, including textual, numerical, graphic, cartographic, narrative, or audiovisual.
Information Asset	Information and systems that provide value to an agency or organization.
Integrity	Integrity is the protection of information from tampering, forgery, or accidental changes. It ensures that messages are accurately received as they were sent, and computer errors or non-authorized individuals do not alter information.
Intrusion detection	Pertaining to techniques, which attempt to detect intrusion into a computer or network by observation of actions, security logs, or audit data. detection of break-ins or attempts either manually or via software expert systems that operate on logs or other information available on the network.
Least Functionality	The organization configures information systems to provide only essential capabilities, and disables unused or unnecessary components of information systems to prevent unauthorized connection of devices, unauthorized transfer of information, and unauthorized tunneling.

Term	Definition
Least Privilege	Granting users, programs, or processes only the access they specifically need to perform their business task and no more.
Multifactor Authentication	Using more than one of the following factors to authenticate to a system: Something you know (e.g., user-ID, password, personal identification number (PIN), or passcode); something you have (e.g., a one-time password authentication token, 'smart card'); something you are (e.g., fingerprint, retina scan).
Privileged Account	A privileged account is an account which provides increased access and requires additional authorization. Examples include a network, system, or security administrator account.
Remote Access	The connection of a remote computing device via communication lines such as ordinary phone lines or wide area networks to access network applications and information.
Risk	The probability that a particular threat will exploit a particular vulnerability of the system.
Risk Assessment	The process of identifying threats to information or information systems, determining the likelihood of occurrence of the threat, and identifying system vulnerabilities that could be exploited by the threat.
Security (IT)	Measures and controls that protect IT systems/information against denial of access and unauthorized (accidental or intentional) disclosure, modification, or destruction of ITs and data. IT security includes consideration of all hardware and/or software functions.

Term	Definition
System	An interconnected set of information resources under the same direct management control that shares common functionality. A system normally includes hardware, software, applications, and communications.
Threat	A potential circumstance, entity, or event capable of exploiting vulnerability and causing harm. Threats can come from natural causes, human actions, or environmental conditions. A threat does not present a risk when there is no vulnerability.
User	Any State Entity, federal government entity, political subdivision, their employees or third-party contractors or business associates, or any other individuals who are authorized by such entities to access a system for a legitimate government purpose.
Vulnerability	A weakness that can be accidentally triggered or intentionally exploited.

Appendix C – Review, Revision, Approval Log

Ownership of this policy is assigned to DOA, DET Bureau of Security. As such, the DOA, DET Bureau of Security is responsible for the maintenance, update(s), and review of this document annually before the anniversary of the effective date.

Version	Revision or Review Date	Description of Change(s)	Reviewer/Author	Date Approved
3.0	11/03/20	Draft Executive Branch IT Security Policy Handbook submitted to Agency Security Officers, Agency IT Directors, DOA Secretary's Office and Agency Administrative Officers for review.	Reviewer: WI ISAC, ITDC, DOA Secretary's Office, AOs Author: DOA/DET/BOS	11/11/20
4.0	4/1/2022	Draft Executive Branch IT Security Policy Handbook submitted to the Agency Security Officers and Agency IT Directors for review.	Reviewer: WI ISAC, Enterprise IT Author: DOA/DET	6/24/2022
5.0	7/14/2023	Draft Executive Branch IT Security Policy Handbook submitted to the Agency Security Officers and Agency IT Directors for review.	Reviewer: WI ISAC, Enterprise IT Author: DOA/DET	8/1/2023
6.0	6/25/2024	Draft Executive Branch IT Security Policy Handbook submitted to the Agency Security Officers and Agency IT Directors for review.	Reviewer: WI ISAC, Enterprise IT Author: DOA/DET	7/31/2024
7.0	6/16/2025	Draft Executive Branch IT Security Policy Handbook submitted to the Agency Security Officers, and Agency IT Directors and Administrative Officers for review.	Reviewer: WI ISAC, Enterprise IT, Administrative Officer Counsel Author: DOA/DET	7/28/2025
8.0	3/30/2026	ADA Compliance and template	Kerry Hawkins	_3/30/2026

NOTE: Keep only the origination and the last 10 years of update information. Only notate prior three revisions. Include only interim/final revision statuses.